

INFORME DE PRUEBAS DE SEGURIDAD

Vulnerability Assessment & Penetration Testing

Secure DevSecOps	OWASP Juice Shop
Autor	Jhon Alex Prada Gomez
Fecha	12 de agosto de 2026
Clasificación	Entregable técnico

Alcance del documento

Informe consolidado basado únicamente en PoC y evidencias existentes. No declara remediaciones ni retests que no fueron ejecutados.

Estado global: riesgo alto por fallos confirmados de autenticación, autorización y manejo de entrada no confiable.

1. Resumen ejecutivo

Se evaluó OWASP Juice Shop y el repositorio mediante pruebas manuales y automatizadas. La evidencia confirmó SQL Injection en login, ausencia de rate limiting, IDOR en el carrito y XSS reflejado en búsqueda. Gitleaks no identificó secretos. JWT, Mass Assignment, Logging PII y Stored XSS no fueron reproducibles bajo las condiciones evaluadas.

Riesgo global

ALTO. La SQL Injection permite acceso administrativo no autorizado; IDOR expone recursos ajenos; la ausencia de rate limiting facilita fuerza bruta; XSS permite ejecución de contenido activo en el navegador.

Top 3 y acción inmediata

- SQL Injection: priorizar consultas parametrizadas y retest de autenticación.
- IDOR: validar propiedad del recurso en servidor antes de responder.
- Missing Rate Limiting: limitar por IP/cuenta, aplicar retrasos y monitoreo.
- Acción inmediata: restringir exposición del entorno vulnerable, preservar evidencia y planificar correcciones verificables.

ID	Prueba	Resultado	Evidencia
V-01	SQL Injection	CONFIRMADA	Burp + captura
V-02	JWT	No reproducible	401 invalid signature
V-05	Mass Assignment	No reproducible	401 antes de lógica
V-07	Rate Limiting	CONFIRMADA	30 intentos sin 429
V-08	Logging PII	No reproducible	Log disponible
V-09	IDOR	CONFIRMADA	HTTP 200 / basket ajeno
V-10	Hardcoded Credentials	No identificada	Gitleaks limpio
HA-01	XSS reflejado	CONFIRMADA	Alert ejecutado
PA-01	Stored XSS	No reproducible	Payload no ejecutado

2. Alcance y metodología

Alcance

- Instancia local OWASP Juice Shop en 127.0.0.1:3000.
- Endpoints de autenticación, carrito, API B2B, búsqueda y feedback.
- Registros disponibles y repositorio para detección de secretos.
- Evidencias almacenadas en vapt/evidence.

Fuera de alcance o sin evidencia

- SSRF, XXE y Path Traversal no se reportan como resultados.
- No se implementaron remediaciones ni validaciones posteriores.
- No se atribuye evidencia inexistente al ensayo JWT.

Metodología

- Selección de superficie y endpoints.
- Interceptación y modificación de solicitudes HTTP.
- PoC controladas sobre entorno local.
- Revisión de respuestas, comportamiento de navegador y logs.
- Detección de secretos con Gitleaks.
- Clasificación basada exclusivamente en evidencia.

Criterio

No reproducible significa que no se obtuvo evidencia suficiente en las condiciones evaluadas; no garantiza ausencia de la vulnerabilidad.

3. Superficie de ataque

Componente	Interfaz	Autenticación	Pruebas
Login	POST /rest/user/login	No	SQLi, JWT, rate limit
Carrito	GET /rest/basket/{id}	Sí	IDOR
API B2B	POST /b2b/v2/orders	Sí / firma específica	Mass Assignment
Búsqueda	/#/search?q=...	No	XSS reflejado
Feedback/Admin	Formulario + panel	Sí	Stored XSS
Repositorio	Archivos locales	N/A	Gitleaks

4.1 V-01 - SQL Injection (CWE-89)

Severidad	CRÍTICA - CVSS 9.8
Endpoint	POST /rest/user/login
Estado	Confirmada

Descripción y PoC

El payload ' OR 1=1 -- produjo HTTP 200 y acceso como admin@juice-sh.op sin contraseña.

Impacto C/I/D y privacidad

Confidencialidad alta; integridad alta; disponibilidad media. Puede permitir acceso no autorizado a datos personales, afectando el principio de seguridad de la Ley 1581.

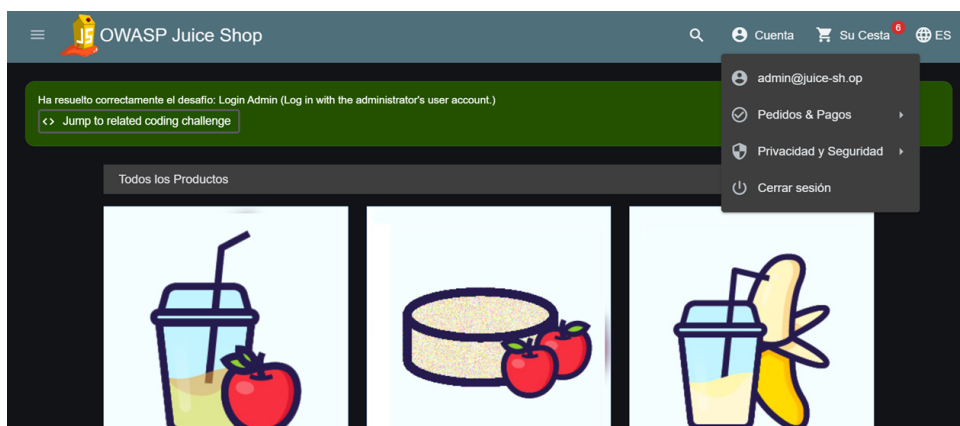
Remediación recomendada

Usar consultas parametrizadas, evitar concatenación, validar entradas y monitorear autenticación.

Evidencia

[evidence/burp/V01_SQLi_Request_Response.txt](#): [evidence/screenshots/V01_SQLi_Login_Bypass.png](#)

Remediación y retest: pendientes; no existe evidencia de implementación posterior.



4.2 V-07 - Missing Rate Limiting (CWE-307)

Severidad	ALTA - CVSS 7.5
Endpoint	POST /rest/user/login
Estado	Confirmada

Descripción y PoC

Treinta intentos consecutivos recibieron HTTP 401 sin HTTP 429, bloqueo, CAPTCHA o retraso observable.

Impacto C/I/D y privacidad

Facilita fuerza bruta y credential stuffing; puede afectar cuentas y capacidad del servicio.

Remediación recomendada

Rate limit por IP/cuenta, backoff, bloqueo temporal, CAPTCHA adaptativo, MFA y alertas.

Evidencia

poc-rate-limit.ps1: [evidence/logs/rate-limit-test.txt](#): [evidence/screenshots/V07_Rate_Limit_Test.png](#)

Remediación y retest: pendientes; no existe evidencia de implementación posterior.

```
PS C:\Proyectos\secure-devsecops-juiceshop> powershell -ExecutionPolicy Bypass -File .\vapt\poc-rate-limit.ps1
=====
V-07 Missing Rate Limiting PoC
=====
Attempt 01 -> HTTP 401
Attempt 02 -> HTTP 401
Attempt 03 -> HTTP 401
Attempt 04 -> HTTP 401
Attempt 05 -> HTTP 401
Attempt 06 -> HTTP 401
Attempt 07 -> HTTP 401
Attempt 08 -> HTTP 401
Attempt 09 -> HTTP 401
Attempt 10 -> HTTP 401
Attempt 11 -> HTTP 401
Attempt 12 -> HTTP 401
Attempt 13 -> HTTP 401
Attempt 14 -> HTTP 401
Attempt 15 -> HTTP 401
Attempt 16 -> HTTP 401
Attempt 17 -> HTTP 401
Attempt 18 -> HTTP 401
Attempt 19 -> HTTP 401
Attempt 20 -> HTTP 401
Attempt 21 -> HTTP 401
Attempt 22 -> HTTP 401
Attempt 23 -> HTTP 401
```

4.3 V-09 - IDOR (CWE-639)

Severidad	MEDIA - CVSS 6.5
Endpoint	GET /rest/basket/{id}
Estado	Confirmada

Descripción y PoC

Un usuario autenticado solicitó /rest/basket/1 y recibió HTTP 200 con un recurso asociado a UserId 1.

Impacto C/I/D y privacidad

Exposición de información de terceros; posible afectación de integridad si existen operaciones equivalentes de escritura.

Remediación recomendada

Autorizar cada acceso comparando propietario del recurso e identidad autenticada; responder 403/404.

Evidencia

[evidence/burp/V09_IDOR_Basket.txt](#)

Remediación y retest: pendientes; no existe evidencia de implementación posterior.

4.4 HA-01 - XSS reflejado (CWE-79)

Severidad	MEDIA
Endpoint	/#/search?q=...
Estado	Confirmada

Descripción y PoC

Un iframe con javascript:alert ejecutó código en el navegador y mostró el diálogo XSS.

Impacto C/I/D y privacidad

Riesgo de phishing, redirecciones y acceso a información disponible al contexto del navegador.

Remediación recomendada

Codificación contextual, sanitización de HTML no confiable y CSP restrictiva.

Evidencia

[evidence/burp/XSS Search.txt](#): [evidence/screenshots/XSS Search Alert.png](#)

Remediación y retest: pendientes; no existe evidencia de implementación posterior.



5. Pruebas no reproducibles y controles validados

V-02 - JWT

La alteración produjo HTTP 401 con invalid signature. No fue posible forjar sesión. No existe archivo independiente en evidence.

V-05 - Mass Assignment

El atributo role=admin se envió a /b2b/v2/orders, pero la API respondió 401 invalid signature antes de procesar el cuerpo.

V-08 - Logging PII

El registro disponible contiene información operativa, pero no demuestra exposición de PII. La conclusión se limita al período capturado.

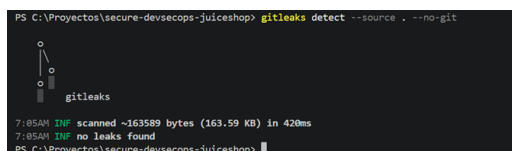
V-10 - Hardcoded Credentials

Gitleaks analizó aproximadamente 163.59 KB con --no-git y reportó no leaks found.

PA-01 - Stored XSS

El payload enviado por Customer Feedback no se ejecutó al revisarlo en Administration.

Evidencia de Gitleaks



```
PS C:\Proyectos\secure-devsecops-juiceshop> gitleaks detect --source . --no-git
graph TD
    gitleaks
    7:05AM[7:05AM] -- INF --> scanned[scanned ~163589 bytes (163.59 KB) in 420ms]
    7:05AM -- INF --> no_leaks[no leaks found]
    PS C:\Proyectos\secure-devsecops-juiceshop>
```

6. Conclusión y plan de tratamiento

La prioridad de tratamiento es SQL Injection, seguida de Missing Rate Limiting, IDOR y XSS reflejado. Cada corrección debe acompañarse de una prueba negativa (payload rechazado) y una prueba positiva (flujo legítimo operativo).

Limitación material

Este informe satisface la consolidación documental y conserva evidencia real, pero no demuestra las ocho remediaciones ni los retests exigidos por la rúbrica original.

7. Anexo - Índice de evidencias

```
vapt/  
|-- VAPT_Report.md  
|-- poc-rate-limit.ps1  
`-- evidence/  
    |-- burp/  
    |-- gitleaks/  
    |-- logs/  
    `-- screenshots/
```

Criterios de interpretación

- Confirmada: evidencia demuestra el comportamiento vulnerable.
- No reproducible: la prueba no confirmó la vulnerabilidad en esas condiciones.
- No identificada: la herramienta no detectó coincidencias en el alcance.
- Pendiente: no existe evidencia suficiente para reportar un resultado.